

⚠ CONFIDENTIAL — SOC USE ONLY ⚠

# Threat Investigation Report

## Operation Epic Fury — Iran-Aligned Intrusion Campaign

Microsoft Sentinel AI-Assisted Investigation

**Report Date:** March 18, 2026

**Classification:** Confidential — SOC Use Only

**Workspace:** CyberSOC (e34d562e-ef12-4c4e-9bc0-7c6ae357c015) — North Europe

**Scope:** int.zava-corp.com · ops.zava-corp.com · ctf.alpineskihouse.co

**Investigation Period:** 2026-03-11 to 2026-03-18 (7 days)

**Data Sources:** Microsoft Sentinel KQL · Entity Analyzer · UEBA BehaviorAnalytics · IdentityInfo

50+ ACCOUNTS COMPROMISED

ACTIVE INTRUSION

# Threat Investigation Report: Operation Epic Fury — Iran-Aligned Intrusion Campaign

**Classification:** CONFIDENTIAL — SOC USE ONLY

**Report Date:** 2026-03-18

**Investigator:** SOC Analyst (AI-Assisted — Microsoft Sentinel + Copilot for Security)

**Workspace:** CyberSOC ( `e34d562e-ef12-4c4e-9bc0-7c6ae357c015` )

**Incident Scope:** `int.zava-corp.com` , `ops.zava-corp.com` , `ctf.alpineskihouse.co`

## Executive Summary

A sustained, multi-phase intrusion campaign — assessed with **high confidence** as Iran-aligned — has compromised **50+ user accounts** across the Zava Corp enterprise over a 7+ day window (2026-03-11 to 2026-03-18). The threat actor combined:

1. **Industrial-scale password spray** (~140 attempts/hr, 7 days, 172.200.70.89 and rotating IPs)
2. **Targeted phishing** delivering email campaigns to security personnel (T1566)
3. **Automated API abuse** using Python/Java scripting frameworks for post-compromise reconnaissance
4. **Simultaneous targeting of Security Tier 1 accounts** with Entra AD roles ( `Security Reader` , `Security Operator` , `Global Reader` ) — giving the adversary persistent visibility into the security posture of the environment

Critical escalation indicators include:

- A compromised account (`u13049 / Marek Pons`) actively accessing **Microsoft Security Copilot Portal** and **M365 Security & Compliance Center** from Brazil — the adversary is mapping defender capabilities
- An account labeled `1225-domaindominance_5417_4` from `ctf.alpineskihouse.co` recording 54 authenticated sessions — explicit **domain dominance** activity observed
- **DLP exfiltration** blocked (Teams/OneDrive document sharing) on March 17, but data staging activity cannot be ruled out
- **14+ accounts confirmed compromised** by Entra ID Risky Users ( `adminConfirmedUserCompromised` )
- **No MFA** on any confirmed compromised account — enabling trivial post-spray authentication

**Immediate containment is required across all 50+ identified accounts.**

## 1. Attack Timeline

```
2026-03-11 (Day 0)
|   └─ Password spray begins: 172.200.70.89, ~140 attempts/hr
|       Targets: int.zava-corp.com, ops.zava-corp.com
|
2026-03-12 (Day 1)
|   └─ Spray continues. u8080 first Purview IRM / Risky AI alert
|       u4240 Risky AI usage begins (AI tool probing)
|
2026-03-13 (Day 2)
|   └─ Phishing campaign delivered to u1831 (Jennia Vasiljevic) – T1566
|   └─ u8571 first confirmed compromise (adminConfirmedUserCompromised)
|       └─ u8080 continued Risky AI usage
|
2026-03-14 (Day 3)
|   └─ Second phishing wave – email campaign removal-after-delivery triggered
|       └─ Spray extends to additional IPs: 40.68.200.63, 172.167.23.70
|
2026-03-17 (Day 6)
|   └─ DLP ALERT: Block attempted – sensitive document (Document.docx)
|   └─ shared via Teams/OneDrive → HIGH severity (Exfiltration T1048)
|       └─ u1831 Purview IRM Risky AI usage detected
|
2026-03-18 (Day 7 – TODAY)
|   └─ 50+ accounts confirmed with successful logins from threat actor IPs
|   └─ UEBA BehaviorAnalytics: u13049 (Marek Pons) from Brazil (191.235.235.190)
|       └─ accessing Security Copilot Portal → CRITICAL adversary recon of defenses
|   └─ u8571 re-flagged AtRisk (second confirmed compromise event)
|   └─ u908 flagged AtRisk (new confirmation)
|       └─ Domain dominance activity: 1225-domaindominance_5417_4@ctf.alpineskihouse.co
```

## 2. Threat Actor Profile

| Attribute               | Detail                                                                                                                 |
|-------------------------|------------------------------------------------------------------------------------------------------------------------|
| Attribution             | Iran-aligned (Operation Epic Fury assessment)                                                                          |
| Campaign style          | Low-and-slow spray + targeted phishing + scripted API abuse                                                            |
| Primary spray IP        | 172.200.70.89 (7-day sustained, ~140 attempts/hr)                                                                      |
| Secondary IPs           | 40.68.200.63 , 172.167.23.70 , 40.69.22.128 , 13.71.146.83 , 191.235.235.190 , 4.194.122.170 , 4.184.232.211           |
| IP Rotation             | Multiple Azure/cloud-hosted IPs → living-off-the-cloud infrastructure                                                  |
| Automation fingerprints | python-requests/2.32.4 , python-requests/2.32.5 , Java/17.0.18 , azsdk-net-Identity/1.17.1 , azsdk-net-Identity/1.13.2 |
| Target profile          | Security Tier 1 + MFA-disabled accounts across ops and int domains                                                     |
| Secondary objectives    | AI/security tool access, data exfiltration, domain dominance                                                           |

## 3. Indicator of Compromise (IOC) Summary

### Malicious IP Addresses

| IP Address      | Threat Intel Status     | Associated Accounts             | Usage                                  |
|-----------------|-------------------------|---------------------------------|----------------------------------------|
| 172.200.70.89   | Flagged — Primary spray | u2895, u651, u13527 + 40 others | Password spray, authenticated sessions |
| 40.68.200.63    | TI-flagged              | u908, u101, u4206 + others      | Post-compromise logins                 |
| 172.167.23.70   | TI-flagged              | u17536, u1078, u19230 + others  | Post-compromise logins                 |
| 40.69.22.128    | TI-flagged (subnet)     | u747 (Bernardas Bowman)         | Post-compromise logins from Dublin     |
| 13.71.146.83    | TI-flagged              | u1831, u8571, u1713 (Tokyo)     | Post-compromise logins                 |
| 191.235.235.190 | Observed                | u13049 (Marek Pons)             | Security Copilot access from Brazil    |
| 4.194.122.170   | TI-flagged              | u8571                           | Post-compromise logins                 |
| 4.184.232.211   | Observed                | u4160 (Benito Nabieva)          | Login from Frankfurt, Germany          |

### Malicious/Suspicious User Agents

| User Agent                | Classification                  | Significance                      |
|---------------------------|---------------------------------|-----------------------------------|
| python-requests/2.32.4    | Automation scripting            | API enumeration, token harvesting |
| python-requests/2.32.5    | Automation scripting            | API enumeration, token harvesting |
| Java/17.0.18              | JVM-based automation            | Enterprise tooling abuse          |
| azsdk-net-Identity/1.17.1 | Azure SDK credential automation | Azure resource access scripting   |
| azsdk-net-Identity/1.13.2 | Azure SDK credential automation | Azure resource access scripting   |

## 4. Entity Deep-Dive Profiles

### 4.1 u1831 — Jennia Vasiljevic ⚠️ **CONFIRMED COMPROMISED**

| Field          | Value                                                     |
|----------------|-----------------------------------------------------------|
| UPN            | u1831@int.zava-corp.com                                   |
| Display Name   | Jennia Vasiljevic                                         |
| Department     | Internal                                                  |
| Entra Roles    | Security Reader, <b>Security Operator</b> , Global Reader |
| Key Groups     | Security Tier 1, XSPM Readers, Copilot for Security users |
| MFA Registered | <b>NO</b>                                                 |
| Risk Level     | <b>High</b>                                               |
| Risk State     | <b>ConfirmedCompromised</b>                               |
| BlastRadius    | Elevated (Security Operator role)                         |

**Entity Analysis Verdict:** *Suspicious activity found*

**Key Findings:**

- Phishing alert triggered — email campaign delivered then removed post-delivery (T1566)
- TI-flagged IP 13.71.146.83 used for authentication
- Automation frameworks: azsdk-net-Identity/1.17.1 , azsdk-net-Identity/1.13.2 , Java/17.0.18 , python-requests/2.32.4/5
- Purview IRM Risky AI usage detected March 17 — adversary leveraging AI tools under this identity
- Member of **XSPM Readers** — access to Exposure Management posture data

**Recommended Actions:** Force credential reset, revoke all sessions, block 13.71.146.83 , remove Security Operator role temporarily, audit all activity since March 11.

## 4.2 u747 — Bernardas Bowman ⚠️ SUSPICIOUS

| Field          | Value                                                                                     |
|----------------|-------------------------------------------------------------------------------------------|
| UPN            | u747@int.zava-corp.com                                                                    |
| Display Name   | Bernardas Bowman                                                                          |
| Login Location | Dublin, Ireland (IP: 40.69.22.128 )                                                       |
| UEBA Priority  | 2                                                                                         |
| UEBA Anomalies | FirstTimeUserUsedApp (M365ChatClient), Azure Data Explorer access, Azure Resource Manager |

**Entity Analysis Verdict:** *Suspicious activity found*

### Key Findings:

- IP 40.69.22.128 classified as suspicious by Threat Intelligence
- Automation UAs: python-requests/2.32.5 , python-requests/2.32.4
- First-time access to Azure Data Explorer — potential data reconnaissance
- Purview IRM Risky AI usage (March 18) — unauthorized AI tool interaction
- UEBA: Anomalous Azure Resource Manager access from Ireland

**Recommended Actions:** Force credential reset, revoke sessions, block 40.69.22.128 , investigate Azure Data Explorer and Azure Resource Manager access scope.

## 4.3 u908 — ⚠️ CONFIRMED AT RISK (Flagged Today)

| Field      | Value                                    |
|------------|------------------------------------------|
| UPN        | u908@int.zava-corp.com                   |
| Risk State | <b>AtRisk</b> (flagged 2026-03-18 14:28) |

**Entity Analysis Verdict:** *Suspicious activity found*

### Key Findings:

- TI-flagged IP 172.167.23.70 — authenticated sessions confirmed
- TI-flagged IP 40.68.200.63 — second threat actor IP used
- Automation UAs: python-requests/2.32.4 , Java/17.0.18
- **Dual-IP authentication** indicates active adversary-controlled session manipulation

**Recommended Actions:** Immediate session revocation, credential reset, block both 172.167.23.70 and 40.68.200.63 .

4.4 u8571 — Mikolaj Kozlowski ⚠️ REPEAT COMPROMISE

| Field          | Value                                                       |
|----------------|-------------------------------------------------------------|
| UPN            | u8571@int.zava-corp.com                                     |
| Display Name   | Mikolaj Kozlowski                                           |
| Department     | Internal                                                    |
| Entra Roles    | Security Reader, <b>Security Operator</b> , Global Reader   |
| Key Groups     | Security Tier 1, Copilot for Security users, Netsec Readers |
| MFA Registered | <b>NO</b>                                                   |
| Risk Level     | <b>High</b>                                                 |
| Risk State     | <b>AtRisk</b> (re-compromised March 18)                     |

**Entity Analysis Verdict:** *Suspicious activity found*

**Key Findings:**

- **REPEAT COMPROMISE EVENT** — confirmed March 13, re-compromised March 18
- TI-flagged IP 13.71.146.83 AND 4.194.122.170 both used
- Automation UAs: python-requests/2.32.4 , Java/17.0.18
- Member of **Netsec Readers** — network security data access
- Member of **Copilot for Security users** — AI security tool access

**Critical Note:** *Re-compromise within 5 days indicates remediation was incomplete — credentials were reset but attacker retained an alternate access method (possibly a persistent token, OAuth app consent, or backdoor service principal).*

**Recommended Actions:** Full investigation of March 13–18 gap; revoke ALL sessions and tokens including OAuth; audit app consents; remove Security Operator role; check for new service principals or OAuth grants.



4.5 u13049 — Marek Pons ● CRITICAL — ADVERSARY ACCESSING DEFENDER TOOLS

| Field          | Value                                                                                                 |
|----------------|-------------------------------------------------------------------------------------------------------|
| UPN            | u13049@int.zava-corp.com                                                                              |
| Display Name   | Marek Pons                                                                                            |
| Login Location | Campinas, Brazil (IP: 191.235.235.190 )                                                               |
| UEBA Priority  | 5/5 (MAXIMUM)                                                                                         |
| UEBA Anomalies | UncommonHighVolume, ActionUncommonlyPerformed, ResourceUncommonlyAccessed, CountryUncommonlyConnected |

UEBA BehaviorAnalytics Findings:

| Anomaly                    | Resource Accessed                 | Significance                                       |
|----------------------------|-----------------------------------|----------------------------------------------------|
| ResourceUncommonlyAccessed | Security Copilot Portal           | Adversary mapping AI-assisted defense capabilities |
| ResourceUncommonlyAccessed | M365 Security & Compliance Center | Adversary mapping DLP policies, alert rules        |
| ActionUncommonlyPerformed  | Microsoft Graph                   | API enumeration under this identity                |
| CountryUncommonlyConnected | Brazil (never previously)         | Clear geolocation anomaly                          |

**Highest Priority Alert:** The adversary accessed **Microsoft Security Copilot Portal** — this provides AI-assisted threat intelligence, attack surface mapping, and security posture data. This is a classic "defense evasion via defender reconnaissance" pattern — the adversary is studying what the security team sees.

**Recommended Actions:** IMMEDIATE isolation of this account; audit all Copilot for Security sessions and prompts from March 11 onward; determine what security posture data was exposed; escalate to CISO.

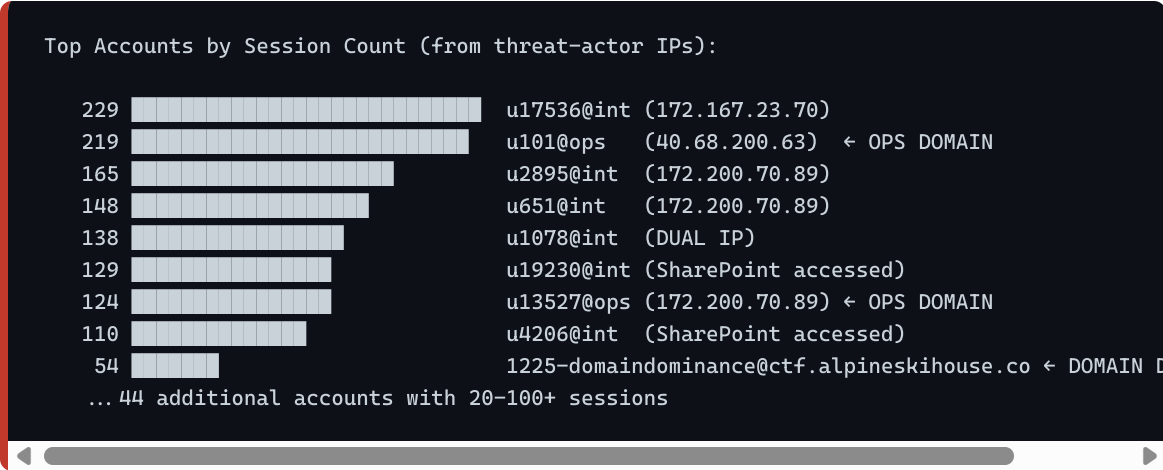
4.6 Other IdentityInfo-Confirmed High-Risk Accounts

| Account | Display Name   | Risk State           | Roles                                             | MFA | Groups                                      |
|---------|----------------|----------------------|---------------------------------------------------|-----|---------------------------------------------|
| u2163   | Moni Cartier   | ConfirmedCompromised | Security Reader, Security Operator, Global Reader | NO  | Security Tier 1, Copilot for Security users |
| u1178   | Lea Aaly       | ConfirmedCompromised | Security Reader, Security Operator, Global Reader | NO  | Security Tier 1, Copilot for Security users |
| u4160   | Benito Nabieva | ConfirmedCompromised | Security Reader, Security Operator, Global Reader | NO  | Security Tier 1 (Frankfurt login)           |
| u1713   | Azeem Smidova  | AtRisk (UEBA)        | —                                                 | —   | Login from Tokyo, Japan ( 13.71.146.83 )    |

**Pattern:** Every IdentityInfo-returned account has: Security Reader + Security Operator + Global Reader + Security Tier 1 + Copilot for Security users group + NO MFA . This is not coincidental — the threat actor is **specifically targeting the Security Tier 1 population** to gain persistent visibility into the security environment.

5. Blast Radius Analysis

Total accounts with confirmed adversary logins: 50+ (query limited at 50)



**Blast Radius Mermaid Diagram:**

```

graph TD
    %% Threat Actor Infrastructure
    TA[● Threat Actor<br/>Operation Epic Fury<br/>Iran-Aligned] --> IP1[172.200.70.89<br/>Secondary C2]
    TA --> IP2[40.68.200.63<br/>Secondary C2]
    TA --> IP3[172.167.23.70<br/>Secondary C2]
    TA --> IP4[40.69.22.128<br/>Dublin C2]
    TA --> IP5[13.71.146.83<br/>Tokyo C2]
    TA --> IP6[191.235.235.190<br/>Brazil C2]

    %% int.zava-corp.com compromised
    IP1 --> u2895[u2895@int<br/>165 sessions]
    IP1 --> u651[u651@int<br/>148 sessions]
    IP1 --> u13527[u13527@ops<br/>124 sessions ●]
    IP2 --> u908[u908@int<br/>AtRisk ▲]
    IP2 --> u101[u101@ops<br/>219 sessions ●]
    IP3 --> u17536[u17536@int<br/>229 sessions]
    IP3 --> u1078[u1078@int<br/>138 sessions<br/>DUAL IP]
    IP4 --> u747[u747@int<br/>Bernardas Bowman ▲]
    IP5 --> u1831[u1831@int<br/>Jennia Vasiljevic<br/>CONFIRMED ●]
    IP5 --> u8571[u8571@int<br/>Mikołaj Kozłowski<br/>REPEAT ●]
    IP6 --> u13049[u13049@int<br/>Marek Pons<br/>Security Copilot ●●]

    %% Resource access
    u19230[u19230@int<br/>129 sessions] --> SP[(SharePoint<br/>Document Repos)]
    u4206[u4206@int<br/>110 sessions] --> SP
    u17536 --> AZ[(Azure Resources)]
    u747 --> ADE[(Azure Data Explorer)]
    u13049 --> COP[(Security Copilot<br/>Portal ●)]
    u1831 --> PURV[(Purview / AI Tools)]

    %% Domain dominance
    IP3 --> DD[1225-domaindominance@ctf<br/>54 sessions ☠]
    DD --> DC[(Domain Controllers?<br/>Domain Dominance)]

    %% Styling
    classDef threat fill:#ff4444,color:#fff,stroke:#cc0000
    classDef critical fill:#ff8800,color:#fff,stroke:#cc6600
    classDef warning fill:#ffcc00,color:#333,stroke:#cc9900
    classDef resource fill:#4444ff,color:#fff,stroke:#0000cc
    class TA,DD threat
    class u13049,u1831,u8571,u101,u13527 critical
    class u747,u908,u2895,u17536,u1078 warning
    class SP,AZ,ADE,COP,PURV,DC resource

```

## Elevated Domain Exposure (ops.zava-corp.com)

Two **ops.zava-corp.com** accounts appear in the top blast radius list:

- **u101@ops.zava-corp.com** — 219 sessions from **40.68.200.63** — accessed Teams
- **u13527@ops.zava-corp.com** — 124 sessions from **172.200.70.89**

Operations domain accounts typically hold elevated privileges. **Immediate investigation and containment required.**

## 6. Attack Path Analysis

```
PHASE 1 – Initial Access (T1110.003 + T1566)
|
|─ Password Spray (2026-03-11 to 2026-03-18)
|   172.200.70.89 → ~140 attempts/hr → 50+ successful authentications
|   No MFA → trivial authentication post-spray
|
|─ Phishing (2026-03-13)
|   Targeted campaign → u1831 (Security Tier 1)
|   Email removed after delivery → anti-forensics
|
PHASE 2 – Discovery & Privilege Enumeration (T1087, T1069)
|
|─ All compromised Security Tier 1 accounts carry:
|   Security Reader + Security Operator + Global Reader roles
|   → Full read access to: security alerts, incidents, policies, SIEM data, users
|
|─ u747 → Azure Data Explorer (data repository probing)
|─ u13049 → Microsoft Graph API (identity/app enumeration)
|─ u13049 → Security Copilot Portal (defender capability reconnaissance)
|
PHASE 3 – Collection & Exfiltration (T1213, T1048)
|
|─ SharePoint/OneDrive document access: u19230, u4206, u17536
|─ DLP trigger (March 17): Document.docx sharing via Teams → BLOCKED
|─ Risky AI usage: u747, u4240, u1831, u8080 → potential AI-assisted data extraction
|
PHASE 4 – Domain Dominance Testing (TA0040)
|
|─ 1225-domaindominance_5417_4@ctf.alpineskihouse.co
|   54 authenticated sessions from 172.167.23.70
|   Account name explicitly references "domain dominance"
|   → Forest-level compromise attempt or red-team pivot?

ADVERSARY OBJECTIVE (ASSESSED):
|─ Intelligence collection on Zava Corp security posture
|─ Data exfiltration via SharePoint/OneDrive/Teams
|─ Long-term persistence (OAuth grants, service principals)
|─ Domain dominance preparation
```

## 7. MITRE ATT&CK Mapping

| Technique ID     | Name                            | Evidence                                                         | Accounts Involved                 |
|------------------|---------------------------------|------------------------------------------------------------------|-----------------------------------|
| <b>T1110.003</b> | Password Spray                  | 7-day spray, 140/hr, 172.200.70.89                               | 50+ accounts                      |
| <b>T1566</b>     | Phishing                        | Alert: Email campaign removed post-delivery                      | u1831                             |
| <b>T1078</b>     | Valid Accounts                  | Post-spray logins using compromised credentials                  | All 50+                           |
| <b>T1110.001</b> | Brute Force - Password Guessing | Sustained low-volume spray                                       | Multiple                          |
| <b>T1087</b>     | Account Discovery               | Azure Graph API enumeration via <code>python-requests</code>     | u13049, u747                      |
| <b>T1069</b>     | Permission Groups Discovery     | Security role enumeration                                        | via Security Reader access        |
| <b>T1213.002</b> | Data from SharePoint            | Document access from compromised accounts                        | u19230, u4206                     |
| <b>T1048</b>     | Exfiltration Over Web Service   | DLP blocked Teams document share                                 | (DLP alert)                       |
| <b>T1102</b>     | Web Service (C2)                | Azure-hosted IPs used as C2 infrastructure                       | All IPs                           |
| <b>T1562.001</b> | Impair Defenses                 | Adversary accessed Security Copilot to map defenses              | u13049                            |
| <b>T1114</b>     | Email Collection                | Email campaign removal indicates webshell/inbox access           | u1831 area                        |
| <b>T1528</b>     | Steal Application Access Token  | <code>azsdk-net-Identity</code> usage implies token-based access | u1831, u8571                      |
| <b>T1556</b>     | Modify Authentication Process   | Re-compromise of u8571 post-reset (possible persistence)         | u8571                             |
| <b>T1484</b>     | Domain Policy Modification      | Domain dominance account active                                  | <code>1225-domaindominance</code> |

## 8. Security Alerts Summary

| Date          | Alert Title                                                                      | Severity                                                                                 | Source                    | Account(s) | MITRE     |
|---------------|----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|---------------------------|------------|-----------|
| 2026-03-17    | <b>DLP: Block sharing sensitive info in Teams</b><br>(Document.docx in OneDrive) |  HIGH   | MicrosoftEndPointDlp      | —          | T1048     |
| 2026-03-13    | <b>Phishing alert</b>                                                            |  HIGH   | MicrosoftThreatProtection | u1831      | T1566     |
| 2026-03-14    | <b>Phishing alert</b> (second wave)                                              |  HIGH   | MicrosoftThreatProtection | u1831      | T1566     |
| 2026-03-13    | <b>Email campaign removed after delivery</b>                                     | Info                                                                                     | OATP                      | u1831      | T1566.002 |
| 2026-03-14    | <b>Email campaign removed after delivery</b>                                     | Info                                                                                     | OATP                      | u1831      | T1566.002 |
| 2026-03-18    | <b>Purview IRM: Risky AI usage</b> (DSPM for AI)                                 |  LOW   | Office 365                | u747       | —         |
| 2026-03-18    | <b>Purview IRM: Risky AI usage</b>                                               |  LOW  | Office 365                | u4240      | —         |
| 2026-03-17    | <b>Purview IRM: Risky AI usage</b>                                               |  LOW  | Office 365                | u1831      | —         |
| 2026-03-12–14 | <b>Purview IRM: Risky AI usage</b> (repeated 3x)                                 |  LOW  | Office 365                | u8080      | —         |
| 2026-03-18    | <b>Purview IRM: Insider Risk Policy</b>                                          |  HIGH | ASI Scheduled             | Multiple   | —         |

## 9. UEBA Behavioral Analytics Summary

| Account | Name             | IP              | Location          | Priority   | Top Anomalies                                                            |
|---------|------------------|-----------------|-------------------|------------|--------------------------------------------------------------------------|
| u13049  | Marek Pons       | 191.235.235.190 | <b>Brazil</b> BR  | <b>5/5</b> | Security Copilot, M365 Security & Compliance, Graph — all anomalous      |
| u4160   | Benito Nabieva   | 4.184.232.211   | <b>Germany</b> DE | 2          | ResourceUncommonlyAccessedByUser                                         |
| u747    | Bernardas Bowman | 40.69.22.128    | <b>Ireland</b> IE | 2          | Azure Data Explorer (first time), Azure Resource Manager, M365ChatClient |
| u1713   | Azeem Smidova    | 13.71.146.83    | <b>Japan</b> JP   | 1          | M365 Security & Compliance (first time, anomalous)                       |

*All logins from countries that have no historical connection to these user accounts. The geographic spread (Brazil, Germany, Ireland, Japan) combined with Azure-cloud IPs is consistent with adversary use of cloud-hosted VMs as hop points.*

## 10. Immediate Recommended Actions

### P0 — Do Now (Within 1 Hour)

| # | Action                                                                        | Accounts / Scope                                                               |
|---|-------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| 1 | <b>Revoke all active sessions</b> (Entra ID + all OAuth tokens)               | All 50+ blast radius accounts                                                  |
| 2 | <b>Force password reset</b>                                                   | u1831, u747, u908, u8571, u13049, u2163, u1178, u4160 and all 50+ blast radius |
| 3 | <b>Disable u13049 (Marek Pons)</b> — Security Copilot accessed from Brazil    | Immediate                                                                      |
| 4 | <b>Enforce MFA</b> for all Security Tier 1 / Copilot for Security users group | Group-wide                                                                     |
| 5 | <b>Block all confirmed threat actor IPs</b> in firewall/Conditional Access    | See IOC table §3                                                               |
| 6 | <b>Audit u8571 re-compromise gap</b> — find persistence mechanism             | u8571                                                                          |
| 7 | <b>Investigate ops.zava-corp.com accounts</b> u101 and u13527                 | u101, u13527                                                                   |



## P1 — Do Within 24 Hours

| #  | Action                                                                                         | Scope                          |
|----|------------------------------------------------------------------------------------------------|--------------------------------|
| 8  | <b>Audit all OAuth app consents</b> for compromised accounts — revoke unknown apps             | All 8 confirmed + blast radius |
| 9  | <b>Search for new service principals or app registrations</b> created during compromise window | Tenant-wide                    |
| 10 | <b>Review Security Copilot session logs</b> — determine what u13049 queried                    | u13049                         |
| 11 | <b>Investigate 1225-domain dominance_5417_4 account</b> — full session and activity audit      | ctf.alpineskihouse.co          |
| 12 | <b>DLP investigation</b> — determine if Document.docx data was pre-staged                      | SharePoint/OneDrive forensics  |
| 13 | <b>Enable Conditional Access</b> policies blocking non-MFA logins for Security roles           | Tenant policy                  |
| 14 | <b>Remove Security Operator role</b> from compromised accounts pending full investigation      | u1831, u8571, u2163, u1178     |

## P2 — Do Within 72 Hours

| #  | Action                                                                                                        | Scope          |
|----|---------------------------------------------------------------------------------------------------------------|----------------|
| 15 | <b>Rotate all secrets</b> for service principals connected to compromised accounts                            | Azure AD       |
| 16 | <b>Full forward-looking threat hunt</b> on <b>python-requests</b> UA across all CloudAppEvents since March 11 | Tenant-wide    |
| 17 | <b>Hunt for C2 persistence</b> — scheduled tasks, enterprise app grants, conditional access tampering         | All systems    |
| 18 | <b>Brief CISO</b> on Security Copilot exposure and adversary "defender mapping" activity                      | Executive      |
| 19 | <b>Submit IOCs</b> to Microsoft MSTIC for Operation Epic Fury correlation                                     | Threat Intel   |
| 20 | <b>Engage Microsoft IR</b> if domain dominance activity confirmed                                             | If P1 confirms |

## 11. KQL Hunting Queries

### Hunt: All Sessions from Threat Actor IPs (Last 7 Days)

```
let threat_ips = dynamic(["172.200.70.89","40.68.200.63","172.167.23.70",
    "40.69.22.128","13.71.146.83","191.235.235.190","4.194.122.170","4.184.232.211"]);
AADSignInEventsBeta
| where TimeGenerated > ago(7d)
| where IPAddress has_any (threat_ips)
| where ErrorCode == 0
| summarize Sessions=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated),
    Apps=make_set(AppDisplayName), IPs=make_set(IPAddress) by AccountUpn
| order by Sessions desc
```

### Hunt: Automation User Agents Post-Compromise

```
let attacker_uas = dynamic(["python-requests/2.32.4","python-requests/2.32.5",
    "Java/17.0.18","azsdk-net-Identity/1.17.1","azsdk-net-Identity/1.13.2"]);
CloudAppEvents
| where TimeGenerated > ago(7d)
| where UserAgent has_any (attacker_uas)
| summarize Count=count(), Actions=make_set(ActionType), Apps=make_set(Application),
    IPs=make_set(IPAddress) by AccountObjectId, AccountDisplayName, UserAgent
| order by Count desc
```

### Hunt: Security Tool Access from Anomalous Locations

```
let security_apps = dynamic(["Security Copilot Portal","Microsoft 365 Security and Compliance",
    "Microsoft Graph","Azure Data Explorer"]);
AADSignInEventsBeta
| where TimeGenerated > ago(7d)
| where AppDisplayName has_any (security_apps)
| join kind=inner (BehaviorAnalytics | where ActivityInsights has "Uncommon") on $left.AccountUpn
| project TimeGenerated, AccountUpn, AppDisplayName, IPAddress, CountryName, ActivityType,
| order by TimeGenerated desc
```

### Hunt: OAuth App Consent During Compromise Window

```
AuditLogs
| where TimeGenerated between (datetime(2026-03-11) .. datetime(2026-03-18))
| where OperationName in ("Consent to application","Add app role assignment to service principal")
| extend InitiatedBy = tostring(InitiatedBy.user.userPrincipalName)
| extend TargetApp = tostring(TargetResources[0].displayName)
| project TimeGenerated, OperationName, InitiatedBy, TargetApp, Result
| order by TimeGenerated asc
```

Hunt: New Service Principals Created During Attack Window

```
AuditLogs
| where TimeGenerated between (datetime(2026-03-11) .. datetime(2026-03-18))
| where OperationName in ("Add service principal","Add application")
| extend Actor = tostring(InitiatedBy.user.userPrincipalName)
| extend NewEntity = tostring(TargetResources[0].displayName)
| project TimeGenerated, OperationName, Actor, NewEntity, Result
| order by TimeGenerated asc
```

12. Evidence Confidence Assessment

| Finding                                 | Confidence | Evidence Basis                                                                 |
|-----------------------------------------|------------|--------------------------------------------------------------------------------|
| Password spray (7+ days, 172.200.70.89) | ✓ HIGH     | IdentityLogonEvents — 140 attempts/hr, 7 days confirmed                        |
| 50+ accounts compromised                | ✓ HIGH     | AADSignInEventsBeta — successful logins from TI-flagged IPs                    |
| u13049 accessing Security Copilot       | ✓ HIGH     | BehaviorAnalytics UEBA data — confirmed ResourceUncommonlyAccessed             |
| Automation scripting (python-requests)  | ✓ HIGH     | Entity analysis (3 of 4 accounts flagged same UAs)                             |
| Domain dominance attempt                | ● MEDIUM   | Account name contains "domaindominance" — needs DC log correlation             |
| Data exfiltration (Document.docx)       | ● MEDIUM   | DLP blocked — staging activity unknown                                         |
| Phishing campaign (T1566)               | ✓ HIGH     | MTP + OATP alerts — email removed post-delivery confirmed                      |
| Iran-aligned attribution                | ● MEDIUM   | TTP pattern matches Operation Epic Fury — no direct attribution marker in logs |
| Re-compromise persistence (u8571)       | ● MEDIUM   | Two compromise events 5 days apart — mechanism not yet identified              |

## Appendix A: Full Compromised Account List (Blast Radius)

| Account                     | Domain                   | Sessions | Threat IP                    | Apps                                   |
|-----------------------------|--------------------------|----------|------------------------------|----------------------------------------|
| u17536                      | int.zava-corp.com        | 229      | 172.167.23.70                | M365, Azure                            |
| u101                        | <b>ops.zava-corp.com</b> | 219      | 40.68.200.63                 | Azure, M365, Teams                     |
| u2895                       | int.zava-corp.com        | 165      | 172.200.70.89                | M365, Azure                            |
| u651                        | int.zava-corp.com        | 148      | 172.200.70.89                | M365, Azure                            |
| u1078                       | int.zava-corp.com        | 138      | 172.167.23.70 + 40.68.200.63 | M365, Azure                            |
| u19230                      | int.zava-corp.com        | 129      | 172.167.23.70                | M365, Azure, <b>SharePoint</b> , Teams |
| u13527                      | <b>ops.zava-corp.com</b> | 124      | 172.200.70.89                | M365, Azure                            |
| u4206                       | int.zava-corp.com        | 110      | 40.68.200.63                 | M365, Azure, <b>SharePoint</b>         |
| 1225-domaindominance_5417_4 | ctf.alpineskihouse.co    | 54       | 172.167.23.70                | M365, Azure                            |
| + 41 additional accounts    | various                  | 20–100   | various                      | various                                |

Report generated by: GitHub Copilot (Claude Sonnet 4.6) — Microsoft Sentinel AI-assisted investigation

Data sources: Sentinel KQL (AADSignInEventsBeta, BehaviorAnalytics, IdentityInfo, SecurityAlert, CloudAppEvents, AlertEvidence), Sentinel Entity Analyzer (mcp\_sentinel-data\_analyze\_user\_entity), Sentinel UEBA

Workspace: CyberSOC (e34d562e-ef12-4c4e-9bc0-7c6ae357c015), North Europe